Design to reference architectures and benchmarks



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com





Checking in with Globomantics



Globomantics has bought three overlapping security tools

Nobody can name the control any of them satisfies

The auditor wants a mapping to NIST by Friday

Where does the architect start?

Read MCRA as a capability map

MCRA sits inside the Security Adoption Framework

SAF gives you the strategy and the process

MCRA gives you the target architecture

Read it, compare it, and find what's missing or duplicated

What architects actually do with it

Define a target state and find the gaps

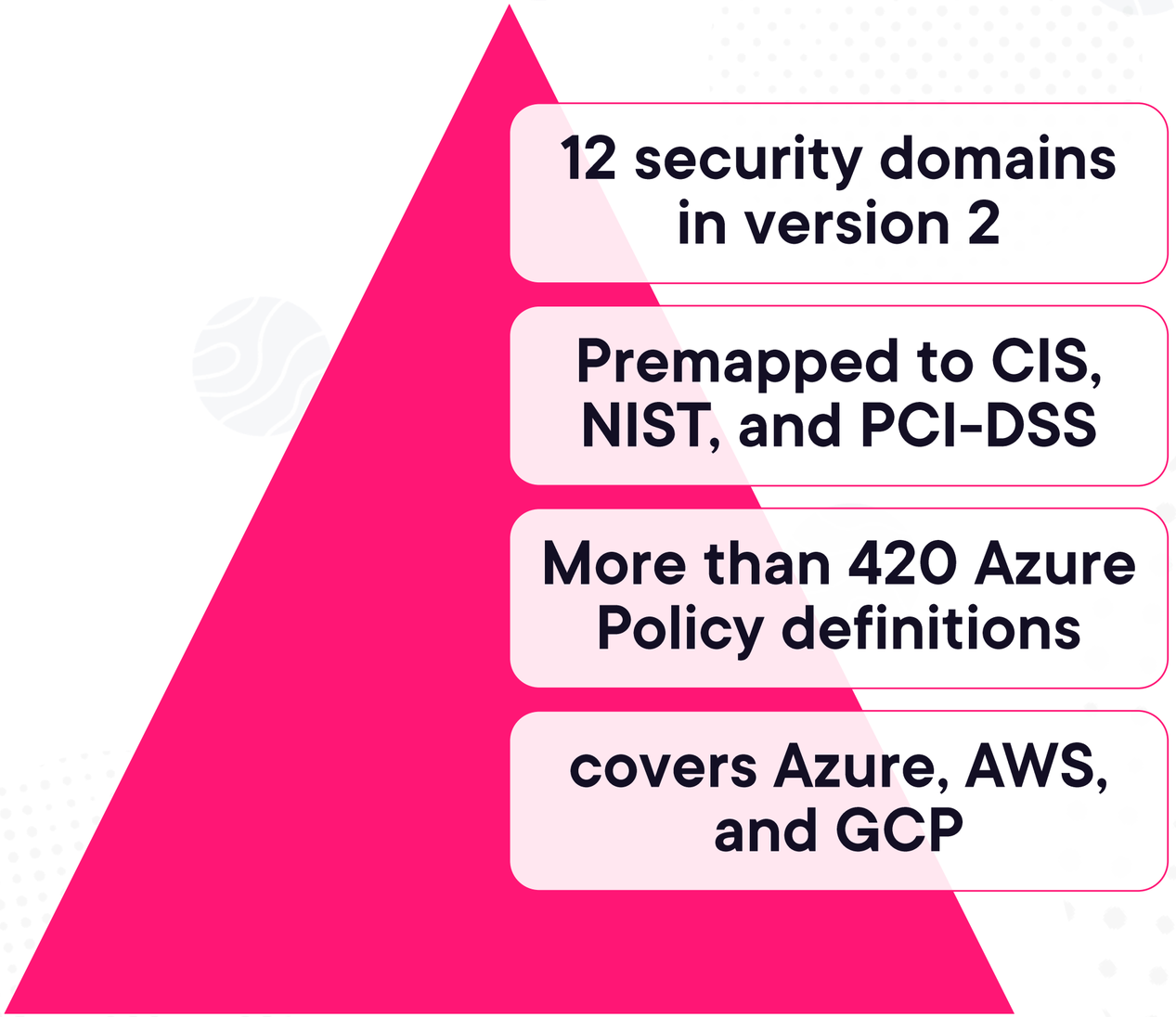
Compare it against what you already own

Find integration points between capabilities

Learn the portfolio without a sales call

Cite controls, not preferences

The benchmark turns instinct into citations



Microsoft Learn, cloud security benchmark documentation

“Microsoft cloud security benchmark v2 is currently in preview. This version supersedes Microsoft cloud security benchmark v1.”

Microsoft Learn, “Describe the Microsoft Cloud Security Benchmark”, **timw.info/csb1**

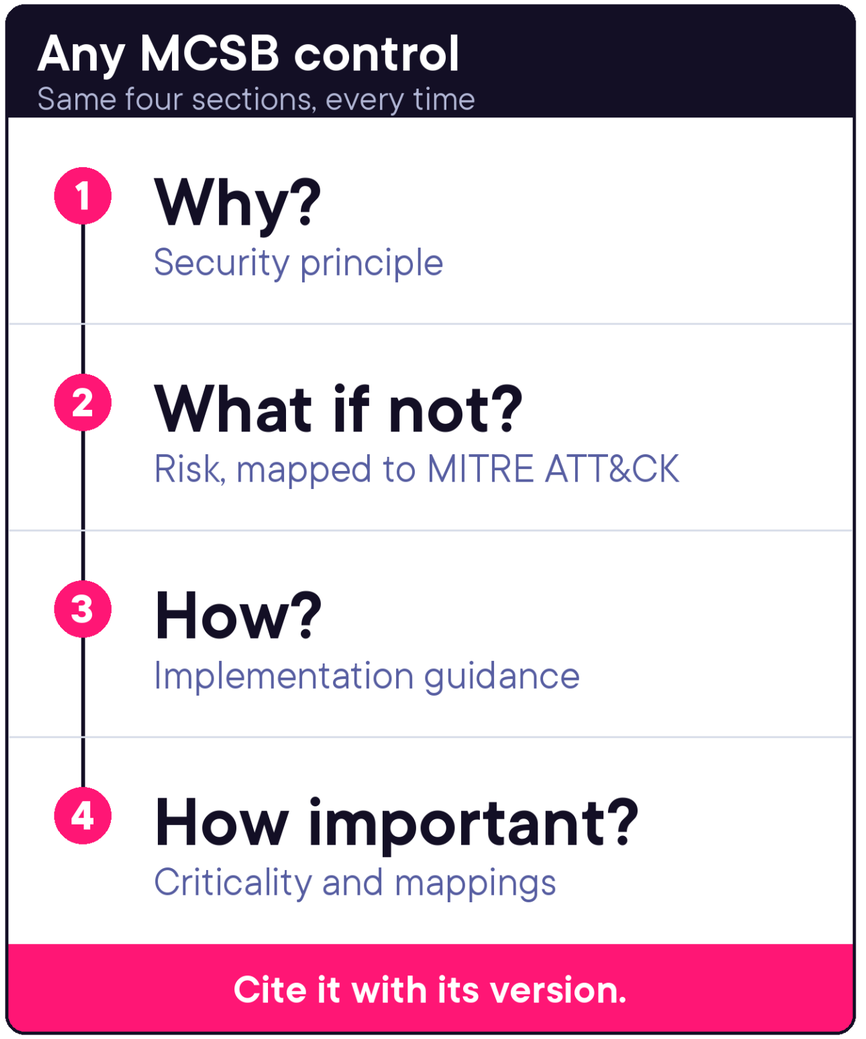
What one control gives you

Security principle: the what and the why

Risk to mitigate, mapped to MITRE ATT&CK

Implementation guidance and a worked example

Criticality level and framework mappings



Defend against insider, external, and supply chain attacks

Three threat classes, three control sets

Insider

- Least privilege, UEBA, DLP, separation of duties

External

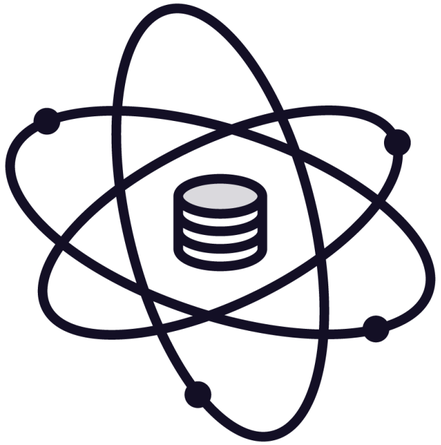
- The attack chain, from entry to escalation

Supply chain

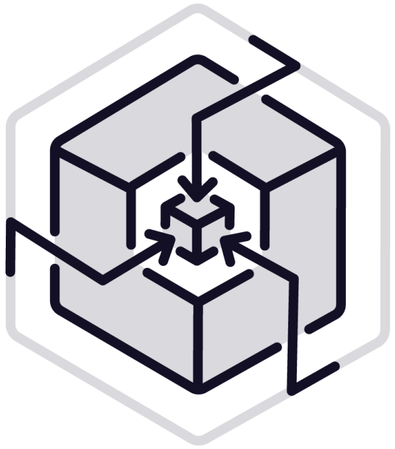
- Verify integrity; limit and isolate vendors

Apply the benchmark to AI workloads

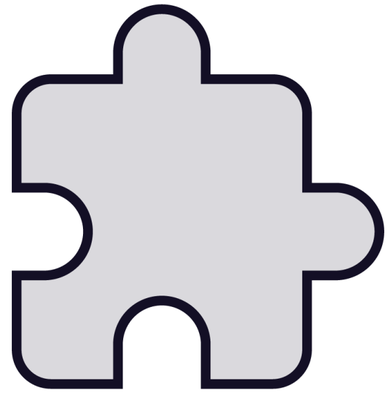
AI security has three pillars



AI platform security: the models and the training data



Monitor and respond: detection and continuous red teaming



AI application security: prompts, plugins, and agent permissions

MCSB v2 (preview): AI-1 through AI-4

AI-1 Ensure use of approved models

AI-2 Implement multi-layered content filtering

AI-3 Adopt safety meta-prompts

AI-4 Apply least privilege for agent functions

MCSB v2 (preview): AI-5 through AI-7

AI-5 Ensure human-in-the-loop

AI-6 Establish monitoring and detection

AI-7 Perform continuous AI red teaming

Sequence a Zero Trust adoption

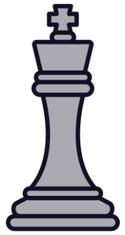
Three principles, and none of them is a product

Verify explicitly on every available signal

Use least privilege access to limit blast radius

Assume breach, and segment accordingly

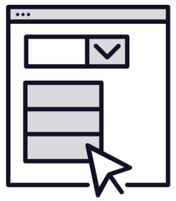
The CAF gives it an order



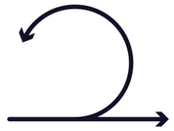
1. Define strategy, with C-suite buy-in



2. Plan, prioritizing quick wins



3. Ready, evaluate, and pilot



4. Adopt, incrementally by functional area



5. Govern and manage; measure it!



Start with "rapidly modernize your security posture"

Demo: Cite the control, and prove it in the estate

Open one benchmark control in Defender for Cloud, read its framework mappings, and name the Azure resources failing it today

Relevant SC-100 practice question

Continuous NIST evidence across the Azure estate. What do you recommend?

A. Azure Policy initiative built from the NIST SP 800-53 definitions

B. Assign the NIST standard in Defender for Cloud regulatory compliance

C. Microsoft Purview Compliance Manager assessment for NIST

D. Defender for Cloud secure score reported monthly to the auditor

Checking out with Globomantics



MCRA maps capabilities; MCSB names the controls

Never cite a control number without its version

Insider, external, and supply chain need different answers

Zero Trust adoption is a sequence, and it starts with posture